# UGH Phishing Incident Response Playbook

Companion to the UGH Cybersecurity Playbook (Threat T4)

**Adeola Oguntuga**

Prepared for SM6375 – Cyber Operations Capstone, University of Houston–Downtown, Spring 2026

Portfolio edition, revised November 2026

*UGH is a fictional organization used as the capstone case study. All names, systems and figures describe that scenario.*

# 1. Purpose, Scope & Governance

### Purpose

Phishing is one of the most common initial access techniques used by threat actors. The UGH Cybersecurity Playbook rates credential phishing (Threat T4) as **Critical (20 of 25)**, one of UGH's two highest risks. This playbook defines how UGH detects, contains, investigates, communicates about, recovers from and learns from a phishing incident, so the response is fast, consistent and documented.

### Definition

Phishing is a social engineering attack in which a threat actor poses as a trusted source to trick a user into revealing credentials or financial information, approving an MFA prompt, opening a malicious attachment or sending money. Modern **adversary-in-the-middle (AiTM)** kits proxy the real Microsoft 365 sign-in page and steal the session cookie, which lets the attacker get past standard MFA.

### Scope

- **In scope:** email phishing against UGH Microsoft 365 users, including credential phishing and AiTM, malicious attachments, and follow-on business email compromise (BEC).
- **Related:** SMS and voice phishing (including Help Desk impersonation, Threat T1) use the account-containment steps in Phase 2 once an account is suspected compromised.
- **Out of scope:** ransomware or domain-wide compromise that develops from a phishing incident. Those incidents follow the main incident response plan, with this playbook's record handed over.

### Framework alignment

Phases follow the **NIST SP 800-61 Rev. 3** incident response lifecycle and the **NIST CSF 2.0** Detect, Respond and Recover functions. Technical steps draw on Microsoft's phishing incident response playbook. Appendix B maps each phase to CSF 2.0 subcategories and NIST SP 800-53 controls.

### Ownership & review

- **Owner:** Ingrid, IT Security Manager. **Approver:** Mr. Roberts, CIO.
- **Review cycle:** every six months, after every SEV-1 or SEV-2 incident, and after the annual tabletop exercise (Section 10).

# 2. Roles & Responsibilities

| Role | Who | Responsibilities in a phishing incident |
|---|---|---|
| **Incident Commander** | Ingrid, IT Security Manager | Declares the incident, sets severity, coordinates all teams and owns the incident record |
| **Executive Sponsor** | Mr. Roberts, CIO | Approves external notifications and major business decisions; receives SEV-1 and SEV-2 updates |
| **IT Security Team** | Security operations | Triage, investigation, purging email, blocking indicators and evidence handling |

| Role | Who | Responsibilities in a phishing incident |
|---|---|---|
| **Cloud Team** | Eric, Cloud Manager | Entra ID and Exchange Online actions: session revocation, MFA method review, mailbox and app-consent cleanup |
| **IT Help Desk** | Virtual support | Takes user reports, routes them to IT Security, and resets passwords and MFA using verified identity |
| **IT Desktop Support** | In-person support | Isolates, collects and reimages affected devices |
| **Application Development** | Gina, App Dev Director | Rotates exposed API tokens and application secrets (including UFO) |
| **Legal & Compliance** | Supporting function | Decides on breach notification, regulatory and contractual obligations, and law enforcement referral |
| **HR & Communications** | Supporting functions | Employee communications and handling of any insider involvement |

## RACI matrix

R = Responsible · A = Accountable · C = Consulted · I = Informed

| Activity | IT Sec Team | IT Sec Mgr | Cloud Team | Help Desk | Desktop | CIO | Legal / Compl. |
|---|---|---|---|---|---|---|---|
| **Triage reported email** | R | A | | C | | | |
| **Assign severity** | R | A | C | | | I | |
| **Contain compromised accounts** | R | A | R | C | | I | |
| **Purge email and block indicators** | R | A | C | | | | |
| **Isolate and image devices** | C | A | | | R | | |
| **Investigate scope and data exposure** | R | A | C | | C | I | C |
| **Notification decision** | C | R | | | | A | R |
| **Internal communications** | C | R | | I | | A | C |
| **Recover and re-enable access** | C | A | R | R | R | | |
| **Lessons learned and playbook update** | R | A | C | C | C | I | C |

## 3. Severity Classification

Severity is assigned at triage and **raised at any point** as new facts emerge. It sets response times, who leads, and how often leadership is updated.

| Severity | Criteria | Response targets | Escalation & updates |
|---|---|---|---|
| **SEV-1** Critical | Any of:<br>• Confirmed account takeover with data accessed or exfiltrated<br>• Privileged or executive account compromised<br>• BEC payment fraud<br>• Several accounts compromised in one campaign | Contain within **15 minutes** of confirmation | IT Security Manager leads; CIO engaged immediately; Legal & Compliance engaged; consider external IR firm and cyber-insurance notice<br>Leadership updates **every 4 hours** |
| **SEV-2** High | Any of:<br>• User entered credentials or approved an MFA prompt<br>• Malicious attachment executed<br>• No confirmed data access yet | Contain within **30 minutes** of confirmation | IT Security Manager leads; CIO informed<br>Leadership updates **daily** |
| **SEV-3** Medium | Any of:<br>• Multiple recipients<br>• Link clicked or attachment opened, with no credential entry or execution | Triage within **1 hour**; purge within **2 hours** | IT Security Team leads; IT Security Manager informed |
| **SEV-4** Low | Reported or blocked email with no user interaction | Triage within **4 business hours** | IT Security Team; close with feedback to the reporter |

## 4. Phase 1: Detection & Triage

| Activity | Steps | Owner |
|---|---|---|
| **Intake** | Sources:<br>• User reports through the **Report** button in Outlook, or a Help Desk ticket (Help Desk forwards to IT Security within **15 minutes**)<br>• Defender for Office 365 alerts (for example, a malicious URL found after delivery)<br>• Entra ID Protection alerts (anomalous token, AiTM sign-in, unfamiliar location) | IT Security Team; IT Help Desk |
| **Analyze the email** | • Review the message in Defender Threat Explorer<br>• Detonate URLs and attachments in a sandbox<br>• Record the sender, return path, SPF/DKIM/DMARC results, originating IP, URLs and file hashes<br>• Determine the type: credential or AiTM phishing (T1566.002), malicious attachment (T1566.001) or BEC | IT Security Team |

| Activity | Steps | Owner |
|---|---|---|
| **Scope recipients** | • Search Threat Explorer for every recipient of the same sender, subject or URL<br>• Use Safe Links click data to identify who clicked | IT Security Team |
| **Confirm user interaction** | For each user who interacted, confirm whether they:<br>• Clicked the link<br>• Entered credentials or approved an MFA prompt<br>• Opened or ran an attachment | IT Security Team; Help Desk |
| **Declare and classify** | • Open an incident record with an ID and start the timeline<br>• Assign severity (Section 3) and notify the IT Security Manager for SEV-3 and above | IT Security Team; IT Security Manager |

## 5. Phase 2: Containment

**Contain first when credentials are involved.** If a user entered credentials or approved an MFA prompt, account containment starts immediately, before deep analysis. Investigation continues in parallel.

| Activity | Steps | Owner |
|---|---|---|
| **Account containment (SEV-2 and above)** | • Revoke all sign-in sessions and refresh tokens in Entra ID<br>• Reset the password and remove any MFA method the user did not register<br>• Disable the account if attacker activity is ongoing<br>• Block the attacker IP addresses in Conditional Access named locations | Cloud Team; IT Security Team |
| **Purge and block** | • Soft-delete the phishing message from every mailbox with Defender for Office 365<br>• Add the sender, domain, URLs and file hashes to the Tenant Allow/Block List and Defender for Endpoint indicators | IT Security Team |
| **Device isolation** | • If an attachment ran, isolate the device in Defender for Endpoint<br>• Preserve the device for forensics: do not wipe or reimage yet | IT Desktop Support; IT Security Team |
| **Stop financial loss (BEC)** | • If payment fraud is suspected, contact Finance and the bank immediately to request a recall of funds | IT Security Manager; Finance |

## 6. Phase 3: Investigation & Analysis

| Activity | Steps | Owner |
|---|---|---|
| **Sign-in review** | • Review Entra ID sign-in logs for affected users over the past 30 days<br>• Look for unfamiliar IPs, locations, devices, user agents and token replay<br>• Check access to SSO applications: Workday, Concur, UFO and others | IT Security Team; Cloud Team |
| **Persistence checks (AiTM / BEC)** | Look for:<br>• New inbox rules that forward, delete or hide mail (T1114.003, T1564.008)<br>• External mail forwarding and delegated mailbox permissions<br>• Newly registered MFA methods or devices (T1098.005)<br>• New OAuth application consents (T1528) | Cloud Team |
| **Data exposure** | • Use Purview Audit (MailItemsAccessed, FileAccessed, FileDownloaded) to find what the attacker read or took<br>• Note any PII (such as Workday data) or confidential company data | IT Security Team |
| **Lateral phishing** | • Check whether compromised accounts sent internal phishing<br>• If so, expand the scope and loop back to Phase 1 | IT Security Team |
| **Evidence handling** | • Preserve the email sample, headers, log exports and device images with chain of custody<br>• Place affected mailboxes on Purview eDiscovery hold | IT Security Team |

## 7. Phase 4: Notification & Communication

Legal & Compliance decide on all external notifications, and the CIO approves them. Notification deadlines start from the time of discovery, so this assessment begins as soon as data exposure is suspected, not after recovery.

| Question | If yes |
|---|---|
| Was personal information (for example, employee data from Workday) accessed or acquired? | Legal assesses applicable state breach-notification laws and starts notification timelines |
| Was customer data or a customer-facing service affected? | Notify affected customers as required by contract |
| Was money transferred (BEC)? | Notify the bank, file a complaint with the FBI's IC3, and refer to law enforcement |
| Does UGH carry cyber insurance? | Notify the carrier as the policy requires, typically before engaging an external IR firm |

### Internal communication

- **Employee advisory** for SEV-3 and above campaigns: what the email looks like, what to do if you clicked, and how to report it.
- **Leadership updates** at the cadence set in Section 3. All external statements are approved by Legal and the CIO.

## 8. Phase 5: Eradication & Recovery

| Activity | Steps | Owner |
|---|---|---|
| **Eradication** | • Remove every malicious inbox rule, forwarding setting, OAuth consent and MFA method found in Phase 3<br>• Run a full Defender scan on affected devices<br>• Reimage any device where malware ran, after the forensic image is taken | Cloud Team; IT Desktop Support |
| **Restore access** | • Re-enable accounts only after identity is verified through the Help Desk Identity Verification Standard (callback to the number on record)<br>• Issue a Temporary Access Pass so the user can register MFA again | IT Help Desk; Cloud Team |
| **Restore data and secrets** | • Recover deleted mail and files from the recycle bin or a verified clean backup<br>• Rotate any exposed API tokens and application secrets | Cloud Team; Application Development |
| **Validate** | • Confirm that Conditional Access policies, firewall rules and DNS settings are unchanged<br>• Watch affected accounts closely for 30 days | IT Security Team |
| **Close** | Close the incident when:<br>• All affected accounts are secured<br>• Persistence has been removed<br>• Notifications are complete<br>• The incident record is documented | IT Security Manager |

## 9. Phase 6: Post-Incident Review

- **Lessons-learned meeting** within 5–10 business days of closing any SEV-1 or SEV-2 incident. It is blameless and attended by every team involved, walks through the timeline and identifies the root cause.
- **Corrective actions** are logged with an owner and due date, and tracked to closure by the IT Security Manager.
- **Detection tuning:** update Defender for Office 365 policies, Tenant Block List entries, Conditional Access and alert rules based on what got through.
- **Targeted training** for affected users through Defender Attack Simulation Training.
- **Governance update:** revise this playbook and contact lists, and reassess Threat T4 in the risk register.

## 10. Metrics, Testing & Maintenance

The IT Security Manager reports these metrics to the CIO every quarter.

| Metric | Definition | Target |
|---|---|---|
| Simulation report rate | Share of phishing-simulation recipients who report the email | ≥ 60% |
| Simulation click rate | Share of recipients who click the simulated link | ≤ 5% |
| Time to triage | From report to severity assigned (SEV-3 and above) | ≤ 1 hour |
| Time to contain | From confirmed credential entry to sessions revoked | ≤ 30 minutes |
| Time to purge | From severity assigned to message removed from all mailboxes | ≤ 2 hours |
| Repeat clickers | Users who click in two or more simulations within 12 months | Decreasing each quarter |
| Corrective actions on time | Post-incident actions closed by their due date | ≥ 90% |

- **Annual tabletop exercise** covering an AiTM phishing scenario that escalates to BEC, with results feeding the playbook review.
- **Semi-annual review** of contacts, escalation paths and tool steps.

# Appendix A: First 30 Minutes Checklist (SEV-2 and above)

- ☐ Open the incident record and start the timeline
- ☐ Assign severity and notify the IT Security Manager
- ☐ Revoke the user's sessions and reset the password
- ☐ Remove MFA methods the user didn't register
- ☐ Block the attacker IP addresses and indicators
- ☐ Find every recipient of the message and soft-delete it from all mailboxes
- ☐ Isolate any device where an attachment ran
- ☐ Check for inbox rules, forwarding and OAuth consents on affected accounts
- ☐ If payment fraud is suspected, call Finance and the bank
- ☐ Inform the CIO (and Legal, if data exposure is suspected)

# Appendix B: Framework Mapping

| Phase | NIST CSF 2.0 subcategories | NIST SP 800-53 Rev. 5 |
|---|---|---|
| **Detection & triage** | DE.CM-09, DE.AE-02, DE.AE-06, DE.AE-08, RS.MA-02, RS.MA-03 | SI-4, SI-8, IR-4, IR-6 |
| **Containment** | RS.MA-01, RS.MA-04, RS.MI-01 | IR-4, AC-2, IA-5 |
| **Investigation** | RS.AN-03, RS.AN-06, RS.AN-07, RS.AN-08 | AU-6, AU-9, IR-4 |
| **Notification** | RS.CO-02, RS.CO-03 | IR-6, IR-7 |
| **Eradication & recovery** | RS.MI-02, RS.MA-05, RC.RP-01, RC.RP-03, RC.RP-05, RC.RP-06, RC.CO-03 | IR-4, CP-10, IA-5 |
| **Post-incident review** | ID.IM-03, ID.IM-04 | IR-4, IR-8, AT-2 |
| **Governance & testing** | GV.RR-02, ID.IM-02, ID.IM-04 | IR-1, IR-3, IR-5, IR-8 |

### MITRE ATT&CK techniques referenced

T1566.001 Spearphishing Attachment · T1566.002 Spearphishing Link · T1557 Adversary-in-the-Middle · T1539 Steal Web Session Cookie · T1078.004 Valid Accounts: Cloud Accounts · T1114.003 Email Forwarding Rule · T1564.008 Email Hiding Rules · T1098.005 Device Registration · T1528 Steal Application Access Token

### References


- NIST. SP 800-61 Rev. 3, Incident Response Recommendations and Considerations for Cybersecurity Risk Management, April 2025.
- NIST. The NIST Cybersecurity Framework (CSF) 2.0, February 2024.
- NIST. SP 800-53 Rev. 5, Security and Privacy Controls for Information Systems and Organizations.
- Microsoft. Incident response playbooks: Phishing investigation.
- MITRE. ATT&CK Enterprise Matrix. attack.mitre.org.